

DevSecOps Final Capstone Project

Enterprise Cloud-Native Application with Automated CI/CD, Terraform EKS, Helm, GitOps & Observability Student: Neerasa Veda Varshit | Enrollment: 24bcs10005 | SST DevOps & Cloud

- Full-stack 3-tier architecture with FastAPI, React 18, and PostgreSQL
- Automated DevSecOps pipeline with Pytest, Bandit, pip-audit, and Aqua Trivy
- AWS Infrastructure as Code using HashiCorp Terraform (VPC, Subnets, EKS)
- GitOps deployment using Helm charts and ArgoCD continuous reconciliation
- Full observability stack with Prometheus metrics and Grafana dashboards

1. Project Overview & Business Domain

High-Reliability Enterprise SaaS Architecture

- Domain: Cloud-native incident tracking & developer productivity SaaS platform
- Target SLA: 99.9% availability with automated horizontal scaling and health probes
- Decoupled Architecture: Independent scaling of React SPA client and FastAPI REST backend
- Compliance: Zero tolerance for HIGH/CRITICAL vulnerabilities via automated pipeline quality gates

2. Technology Stack & Toolchain

Modern Cloud-Native Ecosystem

- Frontend: React 18, Vite, Tailwind CSS, Nginx Alpine Reverse Proxy
- Backend: Python 3.12, FastAPI, SQLAlchemy ORM, Alembic schema migrations

- Database: PostgreSQL 16 ACID-compliant relational persistence with persistent volume claims
- CI/CD & Security: GitHub Actions, Aqua Security Trivy, Bandit SAST, pip-audit, GHCR
- Cloud & Infrastructure: AWS VPC, AWS EKS, HashiCorp Terraform, Helm v3, ArgoCD
- Observability: Prometheus server, ServiceMonitor, Grafana operational dashboards

3. End-to-End System Architecture

Continuous Workflow from Commit to Cluster

- 1. Code: Developer commits clean code to GitHub repository
- 2. CI Pipeline: Automated unit testing, SAST/SCA security scans, Docker build, Trivy scan
- 3. Package & Publish: Immutable images published to GHCR with Git commit SHA tags
- 4. Infrastructure: Terraform provisions multi-AZ VPC and production AWS EKS cluster
- 5. GitOps Delivery: ArgoCD synchronizes Helm releases to the taskboard namespace
- 6. Telemetry: Prometheus scrapes /metrics endpoint, Grafana visualizes golden signals

4. DevSecOps CI/CD Pipeline

Automated Shift-Left Security in GitHub Actions

- Automated push trigger on main branch with path filtering
- Pytest test suite executes 7 test cases covering health, CRUD, and statistics
- Static Application Security Testing (Bandit) and Dependency Scanning (pip-audit)
- Trivy container scanning with build failure on HIGH or CRITICAL CVEs

- Images tagged with immutable Git commit SHA and pushed to GHCR

5. Infrastructure as Code (Terraform)

Declarative AWS Foundation

- Modular VPC (10.20.0.0/16) across 2 Availability Zones with public/private subnets
- Managed AWS EKS cluster with auto-scaling node groups (t3.medium)
- State management with S3 remote backend and DynamoDB state locking
- Least-privilege IAM roles and granular security group boundary definitions
- Clean teardown verification via terraform destroy to prevent unexpected costs

6. Kubernetes & Helm Orchestration

Production-Grade Workload Lifecycle

- Dedicated namespace (taskboard) with resource requests and limits
- Rolling updates with 2+ replicas per service for zero-downtime rollouts
- Startup, Readiness, and Liveness probes ensuring resilient traffic routing
- StatefulSet with PersistentVolumeClaim for database durability
- Modular Helm chart with values-dev.yaml and values-prod.yaml

7. GitOps Delivery with ArgoCD

Declarative Reconciliation & Drift Management

- Git as the single source of truth for all Kubernetes deployment manifests
- Automated sync policy with self-healing and pruning enabled
- Instant drift detection against manual kubectl modifications
- Zero-downtime traffic migration via Nginx Ingress Controller

8. Observability: Prometheus + Grafana

Full-Stack Telemetry & Golden Signals

- FastAPI application instrumented exposing Prometheus-formatted /metrics
- Prometheus scraping target confirmed UP with 15s scrape interval
- Grafana dashboards displaying Request Rate (RPS), Latency, and Error Rates
- Infrastructure metrics: Node CPU, memory pressure, and Pod restart tracking

9. Incident Troubleshooting & Learnings

Production Engineering Excellence

- Systematic 10-step triage methodology applied to production failure drills
- Resolved CrashLoopBackOff, ImagePullBackOff, OOMKilled, and CoreDNS failure modes
- Shift-left security culture proved essential for blocking vulnerable dependencies
- Complete cloud-native delivery lifecycle demonstrated and documented

